

BUSINESS PROPOSAL

Mycroft.ai

A configurable Responsible AI control plane for the enterprise AI portfolio

Team Mycroft.ai · IIT Bombay · Accenture Innovation Challenge 2026, Round 2

Submitted against Track 1: ControlPlane.ai

One control plane, three commitments

Enterprises are not deploying one AI system. They are deploying a portfolio of them, and each carries a different risk signature, latency budget and regulatory obligation. A single checker applied uniformly will be too slow for the first, too noisy for the second, and too shallow for the third.

01

Governance is configuration, not code

An Evaluation Contract, merged with a jurisdiction's policy pack, decides which checks run, how sensitive they are, and what happens when they fire.

02

We never silently rewrite model output

Detect, explain with pinned evidence, then allow, log, route to a human, or block. The enterprise always sees what its model actually said.

03

Every number is measured or labelled

The prototype produces its own precision, recall, FP/FN rates, latency and regression result. Assumptions carry their formula and inputs.

The working prototype runs the whole loop on 294 simulated traces across all three use cases, with no API key and no network.

The problem is the portfolio, not the model

Customer support assistant

External · synchronous

100 ms budget

A wrong answer is a contractual statement to a customer. Blast radius is highest, tolerance for latency lowest.

Internal knowledge assistant

Employees · noisy sources

250 ms budget

Mixed well-governed and loosely governed data. Alert fatigue is the bigger risk than any single wrong answer.

Decision-support tool

Regulated workflow

400 ms budget

The output shapes a decision about a person. Over-flagging is the cheaper error, by a wide margin.

One checker across all three is too slow for the first, too noisy for the second, and too shallow for the third.

Four things that make this genuinely hard

1 The risk families overlap

A fabricated detail about a named person is a hallucination and a privacy exposure at once. Forcing one category loses the second risk or double-counts the incident.

2 There is no real-time ground truth

The same knowledge gap that causes a hallucination blocks its verification. Checkers promising to tell you whether a claim is true are promising something they cannot deliver.

3 One threshold cannot serve one company

Over-flagging teaches users to click through warnings; under-flagging creates liability. The trade-off must be tuned per use case, and most tooling makes it invisible.

4 Enterprises cannot see inside the model

A foundation model consumed over an API offers logits at best. Any checker has to work at the input/output layer, on prompt, retrieval, tool calls and response.

Where the gap actually is

Tracing and storage	Langfuse · LangSmith · Phoenix · Datadog	Commoditised. We read from it.
Guardrails and detection	Bedrock Guardrails · Azure Content Safety · Lakera · NeMo	Crowded and increasingly free.
Evaluation and scoring	Braintrust · DeepEval · RAGAS · Galileo · Patronus	Crowded. A score, not a diagnosis.
Configurable governance across a portfolio	thin	Policy is per-application, not a versioned artifact.
Defect lifecycle: priced, owned, closed, regression-tested	empty	This is where we build.

Anyone can detect a PII leak. Almost nobody turns forty leaks into one owned, priced defect, carries the human's decision into a versioned contract, then proves with a regression run that it worked — and says what it cost.

Two lanes, one action, a loop that closes

FAST LANE	deterministic · inline · 100% of traffic PII with checksum validation · deny lists · loop and budget breakers
SLOW LANE	semantic · asynchronous · never blocks the user grounding · counterfactual bias screen · explanation policy
FUSION	every label recorded, one strictest action taken
DEFECT	clustered by failure signature · priced · evidence-pinned
HUMAN	a reviewer confirms or rejects — nothing moves without this
CONTRACT	versioned, content-hashed, git-diffable configuration change
REGRESSION	re-run the defect's own traces; report benefit AND cost

Why two lanes. Blocking a customer-facing response must be cheap, deterministic and defensible. Judging groundedness is none of those. Measured Fast Lane compute is p95 under 0.05 ms against a 100 ms contract budget.

The Evaluation Contract is the product

```
contracts/use_cases/decision_support.yaml

use_case: decision_support
risk_level: very_high
latency_budget_ms: 400

detectors:
  pii:          { mode: "strict"  }
  hallucination: { mode: "standard" }
  bias:         { mode: "standard" }
  policy:       { mode: "standard" }

actions:
  high:  block
  medium: human_review
  low:   human_review
```

A ratchet, not an override

A policy pack may raise a detector's strictness or an action's severity — never lower it.
A team cannot configure its way out of a regulatory floor.

Content-hashed

customer_support@r2-5ae442dedc. Two contracts that behave identically share a version; any edit produces a new one, and every audit record names it.

The jurisdiction decides what is high risk

Not the team. The EU pack names its own high-risk use cases, so a support chatbot never inherits Annex III obligations by accident.

Regulatory requirements are policy configuration, not application logic.

The same platform, configured three ways

	Customer support	Internal knowledge	Decision support
Risk posture	High	Medium	Very high
Latency budget	100 ms	250 ms	400 ms
PII	standard → strict in EU	standard → strict in EU	strict
Hallucination	standard	permissive — deliberately	standard → strict in EU
Bias	off — no decisions on people	off	standard → strict in EU
Policy	standard	standard	standard → strict in US
High severity →	block	human review	block

The permissive setting on the internal assistant is a deliberate governance choice, not an oversight. The blast radius is an employee who can sanity-check the answer, and alert fatigue is the larger risk. The prototype measures exactly what that choice costs.

Same 264 traces, three policy packs, zero code changes



What changed

- EU raises PII to strict everywhere
- High-severity moves from human review to block, citing Article 22
- Any bias finding is forced to human oversight

+23 blocks

in the EU, on identical traces and identical code

Measured — including where we lose

Generated corpus · 264 traces

Risk family	Precision	Recall
Privacy	0.957	1.000
Hallucination	0.965	0.887
Bias	1.000	1.000
Policy	0.800	1.000
Behaviour	1.000	1.000

Hand-written adversarial holdout · 30 traces

Risk family	Precision	Recall
Privacy	1.000	1.000
Hallucination	0.857	0.750
Bias	1.000	1.000
Policy	1.000	1.000
Behaviour	n/a	n/a

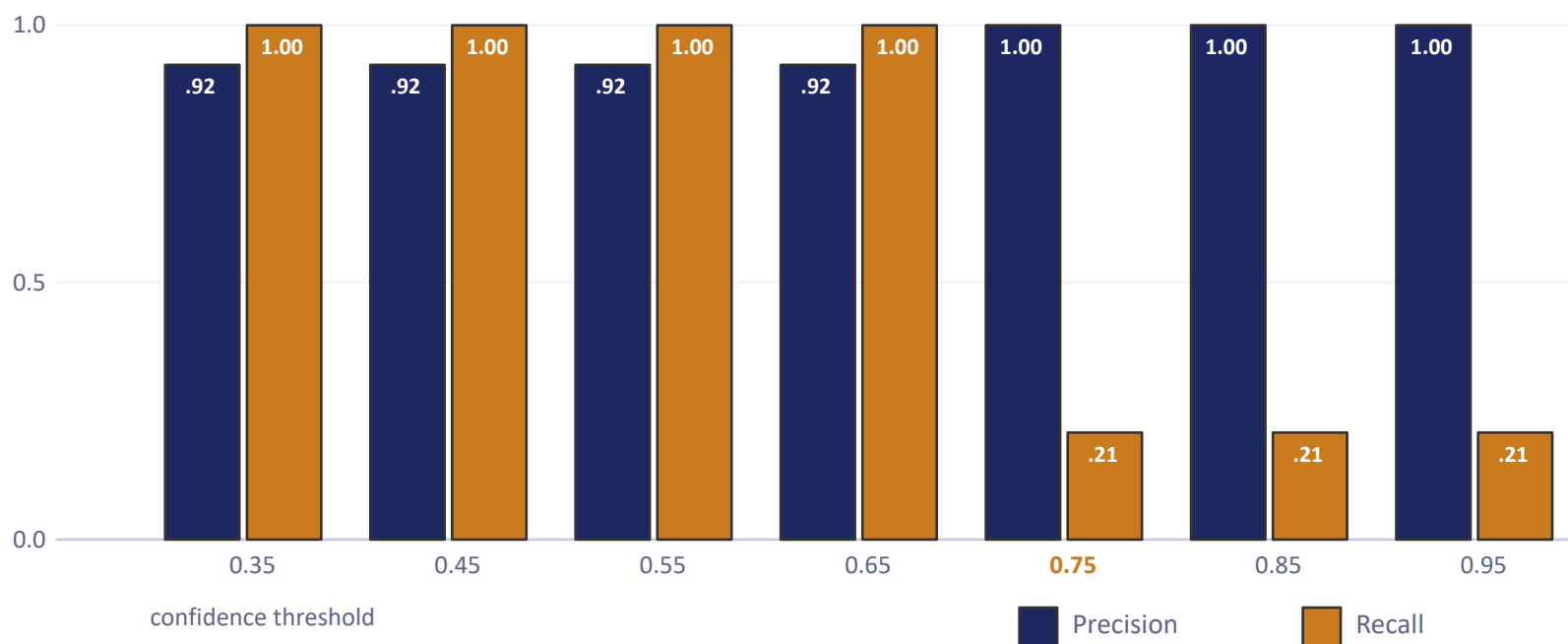
The holdout was written by hand after the detectors, to test the risk rather than the templates.

Hallucination recall drops to 0.75 there. The gap is one specific class — open-ended fabrication with no figure to contradict, like an invented loyalty tier. Our offline judge is built around figures, which is exactly what the optional LLM-judge adapter is for. We would rather show the hole than have it found.

Fast Lane p95 under 0.05 ms of detector compute · 100 ms contract budget · reproducible with no API key and no network

We do not solve the trade-off. We price it.

PII detector, customer support: what each confidence threshold buys, and what it costs



Push the threshold past 0.65 and precision reaches 1.000 — while recall collapses from 1.000 to 0.208. Four in five real leaks walk past.

That is not a bug to fix. It is the decision the contract exists to record — and a governance owner should see its price before signing, not after an incident.

1.000 → 0.208

recall surrendered to buy perfect precision

Findings become a defect that can be closed

DEF-EA14BE

Response restates a governed figure incorrectly

Root cause: the system prompt does not require the answer to quote the retrieved policy. 16 occurrences in 114 customer-support traces.

₹3.55L

estimated cost per month

rate 16/114 = 0.1404 × 12,000 interactions/week × 4.33 weeks = 7,293 occurrences/month × (₹14 rework + 0.07 × ₹95 handoff + ₹28 churn exposure)

Every input is published, and printed beside the figure. Disagree with the ₹95 handoff cost and one line in the contract changes the number.



Nothing changes without the human step. The contract change is versioned, and the regression set is the defect's own traces — so the test cannot drift away from the failure.

The loop closes — and we report the bill

6 → 3

failures reaching the user

–50% on a 30-trace regression set

2 → 13

hallucination false positives

+11 across 114 interactions

60 → 64

interactions needing a human

+4 of 114

```
customer_support@r1-b7cc3c4d4f → customer_support@r2-5ae442dedc
```

The fix is one line: `grounding_required` becomes true, so the assistant must refuse rather than improvise when the corpus does not cover the question. In Round 1 this slide carried a –94%. It was not measured, so it is gone. This one is, and it comes with its cost.

Who buys, who approves, who uses it

Head of AI / platform engineering <i>economic buyer</i>	Several AI systems in production, no consistent way to govern them	One control plane across the portfolio; per-use-case configuration without per-use-case code
Risk, compliance and the DPO <i>approver</i>	Must attest to controls they cannot inspect	Versioned contracts citing the specific regulation, a hash-chained audit trail, human approval in the loop
Application engineer <i>daily user</i>	Told 'the assistant is wrong sometimes' with no reproduction	A defect with a root cause, example traces, evidence spans and a regression set
Internal and external audit <i>verifier</i>	Screenshots and a policy document	A chain of records that cannot be edited after the fact

Initial focus: Indian financial services and regulated SaaS — DPDP obligations today, EU AI Act exposure by August 2026, and several AI use cases already live.

Land read-only, then earn the inline path

Phase 1

0–3 months

Read-only

Ingest from the tracing layer they already run. Slow Lane only, nothing inline, nothing blocked. First priced defect register.

Phase 2

3–6 months

Contracts + Fast Lane

Author contracts with their risk team. Deterministic Fast Lane inline behind a kill switch. First two policy packs.

Phase 3

6–12 months

Close the loop

Human resolution queue, contracts in their own git, automatic regression sets, a CI gate on their deploy pipeline.

Phase 4

12–24 months

Portfolio

Multi-use-case rollout, jurisdiction packs as a subscription, shadow-call bias screening, a managed LLM-judge tier.

Pricing. Platform subscription by governed interaction volume: \$30k–150k ACV for an enterprise running 3–8 AI use cases. The buyer's comparison is not a cheaper tool — it is the compliance headcount reading traces by hand, plus the exposure of the failures nobody is reading.

What could go wrong, and what we do about it

Detection commoditises

Model providers ship guardrails free

We do not sell detection. Detectors are pluggable; the contract, the lifecycle and the audit chain are the product.

Alert fatigue

Over-flagging is how these tools die

The trade-off is measured per threshold before a contract is signed, and review load is reported with every change.

The bias screen is over-read

'The tool said it's biased' is a headline risk

Framed as a screening signal for human review everywhere it appears — in code, in the UI and in the report.

The judge misses open fabrication

Measured: 0.75 recall on the holdout

Reported, not hidden. The LLM-judge adapter is built, and this class is what it is for.

Cost figures are challenged

They are assumptions

Every input is in one file, printed beside every figure, and changeable by the buyer.

We become a single point of failure

A control plane that fails closed takes production down

Fast Lane fails open with an audit record; the judge falls back to the offline path rather than erroring.

Turn every AI failure into a better control — and be able to prove it held.

Anyone can flag a PII leak. Almost nobody turns forty of them into one owned, priced defect, carries a human's decision into a versioned contract, and then proves with a regression run that the fix worked — and tells you what it cost.

`github.com/omchaudhar/mycroft-ai` · `bash run.sh` · no API key, no network